

2.4.4 Set 'ip tftp source-interface' to the Loopback Interface (Automated)

Profile Applicability:

- Level 2

Description:

Specify the IP address of an interface as the source address for TFTP connections.

Rationale:

This is required so that the TFTP servers can easily identify routers and authenticate requests by their IP address.

Impact:

Organizations should plan and implement trivial file transfer protocol (TFTP) services in the enterprise by setting 'tftp source-interface loopback', which enables the TFTP servers to identify routers and authenticate requests by IP address.

Audit:

Perform the following to determine if TFTP services are bound to a source interface:
Verify a command string result returns

```
hostname#sh run | incl tftp source-interface
```

Remediation:

Bind the TFTP client to the loopback interface.

```
hostname(config)#ip tftp source-interface loopback  
{<em>loopback_interface_number</em>}
```

Default Value:

The address of the closest interface to the destination is selected as the source address.

References:

1. http://www.cisco.com/en/US/docs/ios-xml/ios/fundamentals/command/F_through_K.html#GUID-9AA27050-A578-47CD-9F1D-5A8E2B449209

CIS Controls:

Version 6

9.1 Limit Open Ports, Protocols, and Services

Ensure that only ports, protocols, and services with validated business needs are running on each system.

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

3 Data Plane

Services and settings related to the data passing through the router (as opposed to direct to it). The data plane is for everything not in control or management planes. Settings on a router concerned with the data plane include interface access lists, firewall functionality (e.g. CBAC), NAT, and IPSec. Settings for traffic-affecting services like unicast RPF verification and CAR/QoS also fall into this area.

3.1 Routing Rules

Unneeded services should be disabled.

3.1.1 Set 'no ip source-route' (Automated)

Profile Applicability:

- Level 1

Description:

Disable the handling of IP datagrams with source routing header options.

Rationale:

Source routing is a feature of IP whereby individual packets can specify routes. This feature is used in several kinds of attacks. Cisco routers normally accept and process source routes. Unless a network depends on source routing, it should be disabled.

Impact:

Organizations should plan and implement network policies to ensure unnecessary services are explicitly disabled. The 'ip source-route' feature has been used in several attacks and should be disabled.

Audit:

Verify the command string result returns

```
hostname#sh run | incl ip source-route
```

Remediation:

Disable source routing.

```
hostname(config)#no ip source-route
```

Default Value:

Enabled by default

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/ipaddr/command/ipaddr-i4.html#GUID-C7F971DD-358F-4B43-9F3E-244F5D4A3A93>

CIS Controls:

Version 6

9.1 Limit Open Ports, Protocols, and Services

Ensure that only ports, protocols, and services with validated business needs are running on each system.

Version 7

9.2 Ensure Only Approved Ports, Protocols and Services Are Running

Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

3.1.2 Set 'no ip proxy-arp' (Automated)

Profile Applicability:

- Level 2

Description:

Disable proxy ARP on all interfaces.

Rationale:

Address Resolution Protocol (ARP) provides resolution between IP and MAC Addresses (or other Network and Link Layer addresses on non-IP networks) within a Layer 2 network.

Proxy ARP is a service where a device connected to one network (in this case the Cisco router) answers ARP Requests which are addressed to a host on another network, replying with its own MAC Address and forwarding the traffic on to the intended host.

Sometimes used for extending broadcast domains across WAN links, in most cases Proxy ARP on enterprise networks is used to enable communication for hosts with mis-configured subnet masks, a situation which should no longer be a common problem. Proxy ARP effectively breaks the LAN Security Perimeter, extending a network across multiple Layer 2 segments. Using Proxy ARP can also allow other security controls such as PVLAN to be bypassed.

Impact:

Organizations should plan and implement network policies to ensure unnecessary services are explicitly disabled. The 'ip proxy-arp' feature effectively breaks the LAN security perimeter and should be disabled.

Audit:

Verify the proxy ARP status

```
hostname#sh ip int {<em>interface</em>} | incl proxy-arp
```

Remediation:

Disable proxy ARP on all interfaces.

```
hostname(config)#interface {interface}  
hostname(config-if)#no ip proxy-arp
```

Default Value:

Enabled

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/ipaddr/command/ipaddr-i4.html#GUID-AEB7DDCB-7B3D-4036-ACF0-0A0250F3002E>

CIS Controls:

Version 6

11 Secure Configurations for Network Devices such as Firewalls, Routers and switches
Secure Configurations for Network Devices such as Firewalls, Routers and switches

Version 7

11 Secure Configuration for Network Devices, such as Firewalls, Routers and Switches
Secure Configuration for Network Devices, such as Firewalls, Routers and Switches

3.1.3 Set 'no interface tunnel' (Automated)

Profile Applicability:

- Level 2

Description:

Verify no tunnel interfaces are defined.

Rationale:

Tunnel interfaces should not exist in general. They can be used for malicious purposes. If they are necessary, the network admin's should be well aware of them and their purpose.

Impact:

Organizations should plan and implement enterprise network security policies that disable insecure and unnecessary features that increase attack surfaces such as 'tunnel interfaces'.

Audit:

Verify no tunnel interfaces are defined

```
hostname#sh ip int brief | incl tunnel
```

Remediation:

Remove any tunnel interfaces.

```
hostname(config)#no interface tunnel {<em>instance</em>}
```

Default Value:

No tunnel interfaces are defined

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/interface/command/ir-i1.html#GUID-0D6BDFCD-3FBB-4D26-A274-C1221F8592DF>

CIS Controls:

Version 6

11 Secure Configurations for Network Devices such as Firewalls, Routers and switches

Secure Configurations for Network Devices such as Firewalls, Routers and switches

Version 7

11 Secure Configuration for Network Devices, such as Firewalls, Routers and Switches

Secure Configuration for Network Devices, such as Firewalls, Routers and Switches

3.1.4 Set 'ip verify unicast source reachable-via' (Manual)

Profile Applicability:

- Level 2

Description:

Examines incoming packets to determine whether the source address is in the Forwarding Information Base (FIB) and permits the packet only if the source is reachable through the interface on which the packet was received (sometimes referred to as strict mode).

Rationale:

Enabled uRPF helps mitigate IP spoofing by ensuring only packet source IP addresses only originate from expected interfaces. Configure unicast reverse-path forwarding (uRPF) on all external or high risk interfaces.

Impact:

Organizations should plan and implement enterprise security policies that protect the confidentiality, integrity, and availability of network devices. The 'unicast Reverse-Path Forwarding' (uRPF) feature dynamically uses the router table to either accept or drop packets when arriving on an interface.

Audit:

Verify uRPF is running on the appropriate interface(s)

```
hostname#sh ip int {<em>interface</em>} | incl verify source
```

Remediation:

Configure uRPF.

```
hostname(config)#interface {<em>interface_name</em>}
hostname(config-if)#ip verify unicast source reachable-via rx
```

Default Value:

Unicast RPF is disabled.

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/security/d1/sec-cr-i3.html#GUID-2ED313DB-3D3F-49D7-880A-047463632757>

CIS Controls:

Version 6

11 Secure Configurations for Network Devices such as Firewalls, Routers and switches
Secure Configurations for Network Devices such as Firewalls, Routers and switches

Version 7

11 Secure Configuration for Network Devices, such as Firewalls, Routers and Switches
Secure Configuration for Network Devices, such as Firewalls, Routers and Switches

3.2 Border Router Filtering

A border-filtering device connects "internal" networks such as desktop networks, DMZ networks, etc., to "external" networks such as the Internet. If this group is chosen, then ingress and egress filter rules will be required.

3.2.1 Set 'ip access-list extended' to Forbid Private Source Addresses from External Networks (Manual)

Profile Applicability:

- Level 2

Description:

This command places the router in access-list configuration mode, where you must define the denied or permitted access conditions by using the deny and permit commands.

Rationale:

Configuring access controls can help prevent spoofing attacks. To reduce the effectiveness of IP spoofing, configure access control to deny any traffic from the external network that has a source address that should reside on the internal network. Include local host address or any reserved private addresses (RFC 1918).

Ensure the `permit` rule(s) above the final `deny` rule only allow traffic according to your organization's least privilege policy.

Impact:

Organizations should plan and implement enterprise security policies that explicitly separate internal from external networks. Adding 'ip access-list' explicitly permitting and denying internal and external networks enforces these policies.

Audit:

Verify you have the appropriate access-list definitions

```
hostname#sh ip access-list {<em>name | number</em>}
```

Remediation:

Configure ACL for private source address restrictions from external networks.

```
hostname(config)#ip access-list extended {<span><em>name | number</em></span><span>hostname(config-nacl)#deny ip  
{</span><em>internal_networks</em>} any log  
hostname(config<span>-nacl</span>)#deny ip 127.0.0.0 0.255.255.255 any log  
hostname(config<span>-nacl</span>)#deny ip 10.0.0.0 0.255.255.255 any log  
hostname(config<span>-nacl</span>)#deny ip 0.0.0.0 0.255.255.255 any log
```

```
hostname(config<span>-nacl</span>)#deny ip 172.16.0.0 0.15.255.255 any log
hostname(config<span>-nacl</span>)#deny ip 192.168.0.0 0.0.255.255 any log
hostname(config<span>-nacl</span>)#deny ip 192.0.2.0 0.0.0.255 any log
hostname(config<span>-nacl</span>)#deny ip 169.254.0.0 0.0.255.255 any log
hostname(config<span>-nacl</span>)#deny ip 224.0.0.0 31.255.255.255 any log
hostname(config<span>-nacl</span>)#deny ip host 255.255.255.255 any log
hostname(config<span>-nacl</span>)#permit {protocol} {source_ip}
{source_mask} {destination} {destination_mask} log
hostname(config<span>-nacl</span>)#deny any any log
hostname(config)#interface <external_<em>interface</em>>
hostname(config-if)#access-group <<em>access-list</em>> in
```

Default Value:

No access list defined

References:

1. <http://www.cisco.com/en/US/docs/ios-xml/ios/security/d1/sec-cr-i1.html#GUID-BD76E065-8EAC-4B32-AF25-04BA94DD2B11>

CIS Controls:

Version 6

11 Secure Configurations for Network Devices such as Firewalls, Routers and switches
Secure Configurations for Network Devices such as Firewalls, Routers and switches

Version 7

11 Secure Configuration for Network Devices, such as Firewalls, Routers and Switches
Secure Configuration for Network Devices, such as Firewalls, Routers and Switches

3.2.2 Set inbound 'ip access-group' on the External Interface (Manual)

Profile Applicability:

- Level 2

Description:

This command places the router in access-list configuration mode, where you must define the denied or permitted access conditions by using the deny and permit commands.

Rationale:

Configuring access controls can help prevent spoofing attacks. To reduce the effectiveness of IP spoofing, configure access control to deny any traffic from the external network that has a source address that should reside on the internal network. Include local host address or any reserved private addresses (RFC 1918).

Ensure the `permit` rule(s) above the final `deny` rule only allow traffic according to your organization's least privilege policy.

Impact:

Organizations should plan and implement enterprise security policies explicitly permitting and denying access based upon access lists. Using the 'ip access-group' command enforces these policies by explicitly identifying groups permitted access.

Audit:

Verify the access-group is applied to the appropriate interface

```
hostname#sh run | sec interface {<em>external_interface</em>}
```

Remediation:

Apply the access-group for the external (untrusted) interface

```
hostname(config)#interface {external_interface}  
hostname(config-if)#ip access-group {name | number} in
```

Default Value:

No access-group defined